INFORME DE AUDITORÍA

Labs Software Seguro

NOVIEMBRE DE 2026

HALLAZGO #1 Pendiente Validación

Labs Software Seguro v1.0.0

Plantilla: Hallazgo de Seguridad
Ref ID: TCK-A325BE

NOMBRE

Venta de autos

CATEGORÍA

Divulgación de información

VECTOR CVSS

4.3 (CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N)

URL AFECTADA(S)

URL:https://chl-a24bdcf2-16e7-4754-877d-3ad4b8f25974-venta-de-autos.softwareseguro.com.ar/
Endpoint:GET /api/ventas?fecha=YYYY-MM-DD y -GET /api/venta/{id}

DESCRIPCIÓN

Se identificó una posible vulnerabilidad de divulgación de información mediante la enumeración de identificadores de ventas. La API permite consultar las ventas propias, pero al intentar acceder a identificadores correspondientes a registros no autorizados devuelve una respuesta 403 Forbidden. En cambio, cuando el identificador no corresponde a una venta existente, devuelve 404 Not Found. Esta diferencia permite determinar qué identificadores corresponden a ventas existentes de otras concesionarias, aunque no permite acceder directamente a los datos de dichas ventas.

CÓMO SE DETECTÓ

1.Acceder al endpoint /api/ventas?fecha=2025-10-01 para obtener el listado de ventas disponibles.
2.Identificar los IDs de las ventas obtenidas.
3.Utilizar Burp Suite Intruder para consultar secuencialmente otros identificadores mediante /api/venta/{id}.
4.Observar las respuestas del servidor:
200 OK: venta consultable. 403 Forbidden: identificador existente, pero sin autorización para acceder al recurso. 404 Not Found: identificador sin una venta asociada.
5.Comparar los resultados para identificar los registros existentes a los que no se tiene acceso.

HALLAZGO #2 Pendiente Validación

Labs Software Seguro v1.0.0

Plantilla: Hallazgo de Seguridad
Ref ID: TCK-645C2E

NOMBRE

El analista

CATEGORÍA

Race Condition

VECTOR CVSS

5.3 (CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N)

URL AFECTADA(S)

URL:https://chl-bda6cf9e-f7b2-4cdd-b6f4-9e1fb4d24106-el-analista.softwareseguro.com.ar/
Endpoint:POST /asociar/ HTTP/2

DESCRIPCIÓN

Se enviaron dos peticiones HTTP concurrentes mediante Burp Suite (Last-byte synchronization), logrando que ambas recibieran una respuesta 200 y permitiendo asociar dos ventas al mismo vendedor, incumpliendo la restricción de negocio.

CÓMO SE DETECTÓ

1. Ingresé a la aplicación y consulté los endpoints de vendedores y ventas para identificar los parámetros y las reglas de negocio.
2. Realicé peticiones individuales al endpoint `/asociar/` para comprobar las restricciones de asociación.
3. Envié una petición de asociación a Burp Suite Repeater y dupliqué la petición, modificando el parámetro `id_venta` para utilizar una venta diferente y manteniendo el mismo `id_vendedor`.
4. Agrupé ambas peticiones y seleccioné Last-byte synchronization para enviarlas concurrentemente.
5. Comprobé que ambas peticiones fueron aceptadas (HTTP 200 OK) y que dos ventas quedaron asociadas al mismo vendedor.
6. Resultado técnico: se logró vulnerar la restricción de una venta por vendedor mediante una condición de carrera (Race Condition), permitiendo registrar asociaciones que deberían haber sido rechazadas.